

Universidad Tecnológica de Panamá

Facultad de Sistemas Computacionales

Carrera Lic. En Ciberseguridad

Nombre:

Itmar Castillo

Profesora:

Elzer Pineda

Materia:

Ciberseguridad 4

Salón:

1S3231

Asignación:

Wordpress - WAF - Hardening

Año lectivo:

2026

Modulo 1 Instalación LAMP + WordPress

1.1 Preparar el sistema

Se realizó la actualización completa del sistema Kali Linux ejecutando los comandos de actualización de paquetes. Esto garantiza que el sistema cuente con las últimas versiones y parches de seguridad antes de instalar cualquier componente.

```
(itmar@kali)-[~]
$ sudo apt update
[sudo] contraseña para itmar:
Des:2 https://pkgs.tailscale.com/stable/debian bullseye InRelease
Des:1 http://mirrors.ocf.berkeley.edu/kali kali-rolling InRelease [34.0 kB]
Des:3 http://mirrors.ocf.berkeley.edu/kali kali-rolling/main amd64 Packages [21.1 MB]
Des:4 http://mirrors.ocf.berkeley.edu/kali kali-rolling/main amd64 Contents (deb) [53.4 MB]
Des:5 http://mirrors.ocf.berkeley.edu/kali kali-rolling/contrib amd64 Packages [118 kB]
Des:6 http://mirrors.ocf.berkeley.edu/kali kali-rolling/contrib amd64 Contents (deb) [262 kB]
Des:7 http://mirrors.ocf.berkeley.edu/kali kali-rolling/non-free amd64 Packages [189 kB]
Des:8 http://mirrors.ocf.berkeley.edu/kali kali-rolling/non-free-firmware amd64 Packages [15
.4 kB]
Des:9 http://mirrors.ocf.berkeley.edu/kali kali-rolling/non-free-firmware amd64 Contents (de
b) [38.7 kB]
Descargados 75.1 MB en 26s (2,902 kB/s)
Se pueden actualizar 1378 paquetes. Ejecute «apt list --upgradable» para verlos.
```

```
(itmar@kali)-[~]
$ sudo apt upgrade -y
Los paquetes indicados a continuación se instalaron de forma automática y ya no son necesari
os:
libicu76      libjs-source-map  libunibreak6      openjdk-21-jre-headless
libio-pty-perl  libsmdjson30     node-core-util-is  postgresql-common-dev
libipc-run-perl  libsmdutf31     node-process-nextick-args  python3-pysnmp4
libiptcdat0    libteamctl0      openjdk-21-jre
Utilice «sudo apt autoremove» para eliminarlos.
```

```
Actualizando:
7zip                      libnss-mdns
accountsservice          libnss-myhostname
acl                      libnss-systemd
adduser                  libnuma1
adwaita-icon-theme       libobjc-15-dev
apparmor                 libobjc4
apt                     libodbc2
apt-utils               libodbc2
aspell                  libodbcinst2
at-spi2-common           liboeffis1
at-spi2-core            libogg0
atril                   libonig5
bind9-dnsutils          liboobs-1-5
bind9-host              libopenconnect5
bind9-libs              libopenfec1
binutils                libopengl-dev
binutils-common         libopengl0
binutils-x86-64-linux-gnu  libopenh264-8
bluez                  libopenjp2-7
bluez-hcidump           libopenmpt0t64
bluez-obexd             libopenni2-0
bubblewrap              libopus0
```

```

(itmar@kali)-[~]
$ sudo apt install -y curl wget unzip net-tools ufw
[sudo] contraseña para itmar:
curl ya está en su versión más reciente (8.19.0-3).
fijado curl como instalado manualmente.
wget ya está en su versión más reciente (1.25.0-2).
unzip ya está en su versión más reciente (6.0-29).
fijado unzip como instalado manualmente.
net-tools ya está en su versión más reciente (2.10-2).
fijado net-tools como instalado manualmente.
ufw ya está en su versión más reciente (0.36.2-9).
Los paquetes indicados a continuación se instalaron de forma automática y ya no son necesari
os:
  libicu76      libjs-source-map  libunibreak6      openjdk-21-jre-headless
  libio-pty-perl  libsmdjson30     node-core-util-is  postgresql-common-dev
  libipc-run-perl  libsmdutf31     node-process-nextick-args  python3-pysnmp4
  libiptcdata0    libteamctl0      openjdk-21-jre
Utilice «sudo apt autoremove» para eliminarlos.

Resumen:
  Actualizando: 0, Instalando 0, Eliminando: 0, no actualizando: 62

```

Verifica que no hubo errores con:

```

(itmar@kali)-[~]
$ echo $?
0

```

1.2 Instalar Apache

Se instaló el servidor web Apache2 y se habilitó para que inicie automáticamente con el sistema. Se verificó su correcto funcionamiento accediendo a <http://localhost> desde el navegador, mostrando la página de bienvenida de Apache2 Debian.

```

(itmar@kali)-[~]
$ sudo apt install -y apache2
apache2 ya está en su versión más reciente (2.4.66-8).
fijado apache2 como instalado manualmente.
Los paquetes indicados a continuación se instalaron de forma automática y ya no son necesari
os:
  libicu76      libjs-source-map  libunibreak6      openjdk-21-jre-headless
  libio-pty-perl  libsmdjson30     node-core-util-is  postgresql-common-dev
  libipc-run-perl  libsmdutf31     node-process-nextick-args  python3-pysnmp4
  libiptcdata0    libteamctl0      openjdk-21-jre
Utilice «sudo apt autoremove» para eliminarlos.

Resumen:
  Actualizando: 0, Instalando 0, Eliminando: 0, no actualizando: 62

```

```

(itmar@kali)-[~]
$ sudo systemctl enable apache2
Created symlink '/etc/systemd/system/multi-user.target.wants/apache2.service' → '/usr/lib/sy
stemd/system/apache2.service'.

```

```

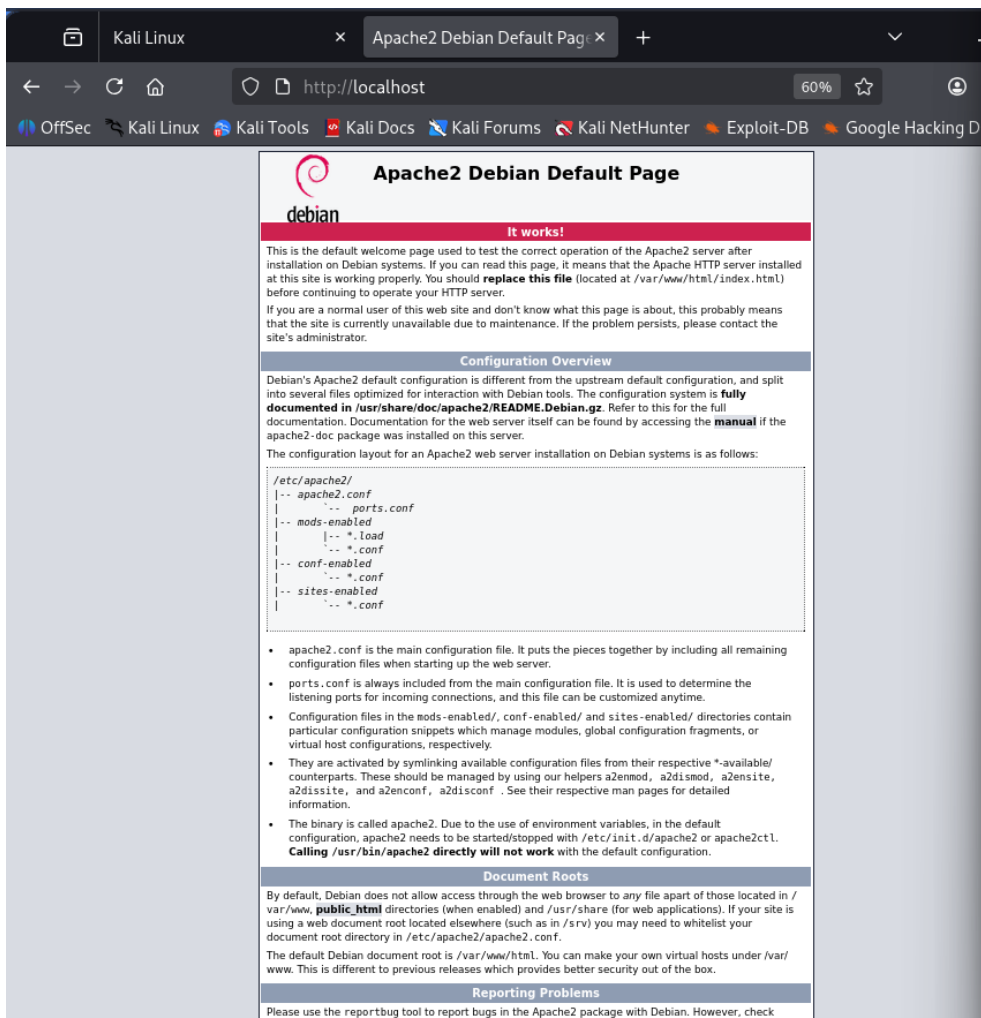
(itmar@kali)-[~]
$ sudo systemctl start apache2

```

```
(itmar@kali)-[~]
$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: disabled)
   Active: active (running) since Tue 2026-05-05 12:44:38 EST; 8s ago
     Invocation: 4e01633839004582965a57ee97e2a616
       Docs: https://httpd.apache.org/docs/2.4/
    Main PID: 164114 (apache2)
   Status: "Processing requests..."
     Tasks: 7 (limit: 9244)
    Memory: 16.4M (peak: 17.1M)
       CPU: 160ms
    CGroup: /system.slice/apache2.service
           └─164114 /usr/sbin/apache2 -k start -DFOREGROUND
             164117 /usr/sbin/apache2 -k start -DFOREGROUND
             164118 /usr/sbin/apache2 -k start -DFOREGROUND
             164119 /usr/sbin/apache2 -k start -DFOREGROUND
             164120 /usr/sbin/apache2 -k start -DFOREGROUND
             164121 /usr/sbin/apache2 -k start -DFOREGROUND
             164122 /usr/sbin/apache2 -k start -DFOREGROUND

may 05 12:44:38 kali systemd[1]: Starting apache2.service - The Apache HTTP Server...
may 05 12:44:38 kali apachectl[164114]: AH00558: apache2: Could not reliably determine the
may 05 12:44:38 kali systemd[1]: Started apache2.service - The Apache HTTP Server.
lines 1-22/22 (END)
```

Verifica en navegador:



1.3 Instalar MySQL pero no existe y se reemplazó por MariaDB

MySQL fue reemplazado por MariaDB como sistema de gestión de base de datos. Se instaló, habilitó y aseguró mediante el script mariadb-secure-installation, configurando autenticación unix_socket y estableciendo una contraseña de root robusta.

```
(itmar@kali)-[~]
$ sudo apt update
$ sudo apt install -y mariadb-server mariadb-client
Obj:1 http://http.kali.org/kali kali-rolling InRelease
Des:2 https://pkgs.tailscale.com/stable/debian bullseye InRelease
Descargados 6,584 B en 1s (10.2 kB/s)
Se pueden actualizar 62 paquetes. Ejecute «apt list --upgradable» para verlos.
mariadb-server ya está en su versión más reciente (1:11.8.6-6).
fijado mariadb-server como instalado manualmente.
mariadb-client ya está en su versión más reciente (1:11.8.6-6).
fijado mariadb-client como instalado manualmente.
Los paquetes indicados a continuación se instalaron de forma automática y ya no son necesari
os:
  libicu76      libjs-source-map  libunibreak6      openjdk-21-jre-headless
  libio-pty-perl  libsmdjson30      node-core-util-is  postgresql-common-dev
  libipc-run-perl  libsmdutf31       node-process-nextick-args  python3-pysnmp4
  libiptcdata0    libteamctl0       openjdk-21-jre
Utilice «sudo apt autoremove» para eliminarlos.

Resumen:
  Actualizando: 0, Instalando 0, Eliminando: 0, no actualizando: 62
```

```
(itmar@kali)-[~]
$ sudo systemctl enable --now mariadb
$ sudo systemctl status mariadb
● mariadb.service - MariaDB 11.8.6 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; enabled; preset: disabled)
   Active: active (running) since Tue 2026-05-05 12:50:10 EST; 5min ago
   Invocation: 37bd62bb65fc4af1bbc77b1d44eff4cd
   Docs: man:mariadb(8)
        https://mariadb.com/kb/en/library/systemd/
   Main PID: 167032 (mariabdb)
   Status: "Taking your SQL requests now..."
   Tasks: 9 (limit: 61015)
   Memory: 154.4M (peak: 160.5M)
   CPU: 2.624s
   CGroup: /system.slice/mariadb.service
           └─167032 /usr/sbin/mariabdb

may 05 12:50:10 kali mariabdb[167032]: 2026-05-05 12:50:10 0 [Note] InnoDB: log sequence nu>
may 05 12:50:10 kali mariabdb[167032]: 2026-05-05 12:50:10 0 [Note] InnoDB: Loading buffer >
may 05 12:50:10 kali mariabdb[167032]: 2026-05-05 12:50:10 0 [Note] Plugin 'FEEDBACK' is di>
may 05 12:50:10 kali mariabdb[167032]: 2026-05-05 12:50:10 0 [Note] Plugin 'wsrep-provider'>
may 05 12:50:10 kali mariabdb[167032]: 2026-05-05 12:50:10 0 [Note] InnoDB: Buffer pool(s) >
may 05 12:50:10 kali mariabdb[167032]: 2026-05-05 12:50:10 0 [Note] Server socket created o>
may 05 12:50:10 kali mariabdb[167032]: 2026-05-05 12:50:10 0 [Note] mariabdb: Event Schedul>
may 05 12:50:10 kali mariabdb[167032]: 2026-05-05 12:50:10 0 [Note] /usr/sbin/mariabdb: rea>
may 05 12:50:10 kali mariabdb[167032]: Version: '11.8.6-MariaDB-6 from Debian' socket: '/r>
may 05 12:50:10 kali systemd[1]: Started mariadb.service - MariaDB 11.8.6 database server.
lines 1-24/24 (END)
```

```
(itmar@kali)-[~]  
$ sudo mariadb-secure-installation
```

NOTE: MariaDB is secure by default in Debian. Running this script is useless at best, and misleading at worst. This script will be removed in a future MariaDB release in Debian. Please read [/usr/share/doc/mariadb-server/README.Debian.gz](#) for details.

Enter root user password or leave blank:

Enter current password for root (enter for none): OK, successfully used password, moving on...

Setting the root password or using the unix_socket ensures that nobody can log into the MariaDB root user without the proper authorisation.

You already have your root account protected, so you can safely answer 'n'.

Switch to unix_socket authentication [Y/n] y
Enabled successfully (or at least no errors was emitted)!
Reloading privilege tables..
... Success!

You already have your root account protected, so you can safely answer 'n'.

Change the root password? [Y/n] y
New password:
Re-enter new password:
Password updated successfully!
Reloading privilege tables..
... Success!

1.4 Instalar PHP + módulos para WordPress

Se instalaron PHP 8.4 junto con todos los módulos requeridos por WordPress: php-mysql, php-curl, php-gd, php-mbstring, php-xml, php-zip y php-intl. Se reinició Apache para aplicar los cambios.

```
(itmar@kali)-[~]
└─$ sudo apt install -y php php-mysql php-curl php-gd php-mbstring php-xml php-zip php-intl
libapache2-mod-php
php -v
php ya está en su versión más reciente (2:8.4+99).
fijado php como instalado manualmente.
php-mysql ya está en su versión más reciente (2:8.4+99).
fijado php-mysql como instalado manualmente.
libapache2-mod-php ya está en su versión más reciente (2:8.4+99).
fijado libapache2-mod-php como instalado manualmente.
Los paquetes indicados a continuación se instalaron de forma automática y ya no son necesari
os:
  libicu76      libjs-source-map  libunibreak6      openjdk-21-jre-headless
  libio-pty-perl  libsmdjson30     node-core-util-is  postgresql-common-dev
  libipc-run-perl  libsimdutf31     node-process-nextick-args  python3-pysnmp4
  libiptcdata0    libteamdctl0     openjdk-21-jre
Utilice «sudo apt autoremove» para eliminarlos.

Instalando:
  php-curl  php-gd  php-intl  php-mbstring  php-xml  php-zip

Instalando dependencias:
  php8.4-curl  php8.4-gd  php8.4-intl  php8.4-mbstring  php8.4-xml  php8.4-zip

Resumen:
  Actualizando: 0, Instalando 12, Eliminando: 0, no actualizando: 62
  Tamaño de la descarga: 1,296 kB
  Espacio necesario: 4,948 kB / 19.2 GB disponible

Des:1 http://mirrors.ocf.berkeley.edu/kali kali-rolling/main amd64 php8.4-curl amd64 8.4.20-
1 [40.5 kB]
Des:2 http://http.kali.org/kali kali-rolling/main amd64 php-curl all 2:8.4+99 [4,120 B]
Des:8 http://http.kali.org/kali kali-rolling/main amd64 php-mbstring all 2:8.4+99 [4,128 B]
Des:6 http://http.kali.org/kali kali-rolling/main amd64 php-intl all 2:8.4+99 [4,124 B]
Des:11 http://elmirror.cl/kali kali-rolling/main amd64 php8.4-zip amd64 8.4.20-1 [29.1 kB]
Des:3 http://kali.download/kali kali-rolling/main amd64 php8.4-gd amd64 8.4.20-1 [37.9 kB]
Des:4 http://http.kali.org/kali kali-rolling/main amd64 php-gd all 2:8.4+99 [4,112 B]
Des:12 http://http.kali.org/kali kali-rolling/main amd64 php-zip all 2:8.4+99 [4,120 B]
Des:5 http://kali.download/kali kali-rolling/main amd64 php8.4-intl amd64 8.4.20-1 [155 kB]
```

Reinicia Apache:

```
(itmar@kali)-[~]
└─$ sudo systemctl restart apache2
```

MÓDULO 1 CREAR BASE DE DATOS WORDPRESS

1.5 Entrar a MariaDB

Se accedió a MariaDB como root y se creó la base de datos wordpress_db con codificación utf8mb4 (soporte completo Unicode). Se creó el usuario wp_user con contraseña segura y se le otorgaron todos los privilegios sobre la base de datos.

```
(itmar@kali)-[~]
└─$ sudo mariadb
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 41
Server version: 11.8.6-MariaDB-6 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]>
```

1.6 Crear base de datos y usuario

```
MariaDB [(none)]> CREATE DATABASE wordpress_db CHARACTER SET utf8mb4 COLLATE utf8mb4_unicode_ci;
Query OK, 1 row affected (0.018 sec)

MariaDB [(none)]>
MariaDB [(none)]> CREATE USER 'wp_user'@'localhost' IDENTIFIED BY 'WpS3cur3P@ss!';
Query OK, 0 rows affected (0.005 sec)

MariaDB [(none)]>
MariaDB [(none)]> GRANT ALL PRIVILEGES ON wordpress_db.* TO 'wp_user'@'localhost';
Query OK, 0 rows affected (0.002 sec)

MariaDB [(none)]>
MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]>
MariaDB [(none)]> EXIT;
Bye

(itmar@kali)-[~]
└─$
```

1.7 Verificar que el usuario sirve

Contraseña: WpS3cur3P@ss!

```
(itmar@kali)-[~]
└─$ mariadb -u wp_user -p wordpress_db
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 47
Server version: 11.8.6-MariaDB-6 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [wordpress_db]>
```


MÓDULO 1 — INSTALAR WORDPRESS

1.8 Descargar WordPress

Se descargó la última versión de WordPress directamente desde wordpress.org, se extrajeron los archivos en `/var/www/html/wordpress` y se configuraron los permisos correctos (755 para directorios, 644 para archivos, propietario `www-data`). Se configuró el archivo `wp-config.php` con las credenciales de base de datos y se generaron las claves secretas (SALTS) desde la API oficial de WordPress.

```
(itmar@kali)-[/var/www/html]
$ sudo wget https://wordpress.org/latest.tar.gz
--2026-05-05 13:31:06-- https://wordpress.org/latest.tar.gz
Resolviendo wordpress.org (wordpress.org)... 198.143.164.252, 2607:f978:5:8002::c68f:a4fc
Conectando con wordpress.org (wordpress.org)[198.143.164.252]:443... conectado.
Petición HTTP enviada, esperando respuesta... 200 OK
Longitud: 27064862 (26M) [application/octet-stream]
Grabando a: «latest.tar.gz»

latest.tar.gz      100%[=====] 25.81M  248KB/s  en 2m 6s
2026-05-05 13:33:13 (210 KB/s) - «latest.tar.gz» guardado [27064862/27064862]
```

1.9 Permisos correctos

```
(itmar@kali)-[/tmp]
$ sudo chown -R www-data:www-data /var/www/html/wordpress

(itmar@kali)-[/tmp]
$ sudo find /var/www/html/wordpress -type d -exec chmod 755 {} \;

(itmar@kali)-[/tmp]
$ sudo find /var/www/html/wordpress -type f -exec chmod 644 {} \;
```

1.1.0 Configurar wp-config.php

```
(itmar@kali)-[/tmp]
$ sudo cp /var/www/html/wordpress/wp-config-sample.php /var/www/html/wordpress/wp-config.php

(itmar@kali)-[/tmp]
$ sudo nano /var/www/html/wordpress/wp-config.php
```

```
// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress_db' );

/** Database username */
define( 'DB_USER', 'wp_user' );

/** Database password */
define( 'DB_PASSWORD', 'WpS3cur3P@ss!' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );

/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8mb4' );
```

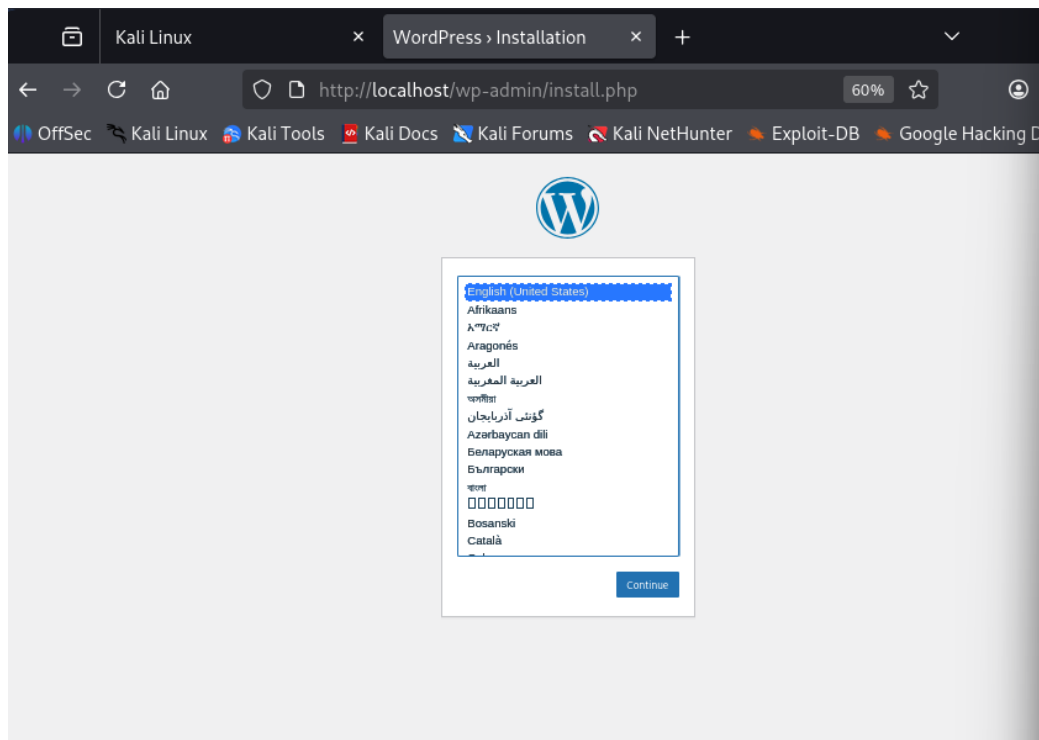
1.1.1 Agregar claves secretas (SALTS)

```
(itmar@kali)-[/var/www/html]
$ curl -s https://api.wordpress.org/secret-key/1.1/salt/
define('AUTH_KEY',
define('SECURE_AUTH_KEY',
define('LOGGED_IN_KEY',
define('NONCE_KEY',
define('AUTH_SALT',
define('SECURE_AUTH_SALT',
define('LOGGED_IN_SALT',
define('NONCE_SALT',

(itmar@kali)-[/var/www/html]
$ sudo nano wp-config.php

(itmar@kali)-[/var/www/html]
$ sudo systemctl restart apache2
```

Vemos que poniendo el localhost sale la configuración del wordpress



MÓDULO 1 — CONFIGURAR APACHE PARA WORDPRESS

2.2 Crear VirtualHost HTTP

Se creó un VirtualHost HTTP en /etc/apache2/sites-available/wordpress.conf con opciones de seguridad básicas (-Indexes, -FollowSymLinks), se activó el módulo rewrite y se desactivó el sitio por defecto. La configuración pasó el test de sintaxis (Syntax OK).

```
(itmar@kali)-[/var/www/html]
$ sudo nano /etc/apache2/sites-available/wordpress.conf
```

```
GNU nano 8.7.1 /etc/apache2/sites-available/wordpress.conf *
<VirtualHost *:80>
    ServerName localhost
    DocumentRoot /var/www/html

    <Directory /var/www/html>
        Options -Indexes -FollowSymLinks
        AllowOverride All
        Require all granted
    </Directory>

    ErrorLog ${APACHE_LOG_DIR}/wordpress_error.log
    CustomLog ${APACHE_LOG_DIR}/wordpress_access.log combined
</VirtualHost>
```

2.3 Activar sitio + rewrite

configtest debe decir: Syntax OK

```
(itmar@kali)-[/var/www/html]
$ sudo a2ensite wordpress.conf
$ sudo a2enmod rewrite
$ sudo a2dissite 000-default.conf
$ sudo apache2ctl configtest
$ sudo systemctl restart apache2
```

Enabling site wordpress.
To activate the new configuration, you need to run:
systemctl reload apache2
Enabling module rewrite.
To activate the new configuration, you need to run:
systemctl restart apache2
Site 000-default disabled.
To activate the new configuration, you need to run:
systemctl reload apache2

AH00112: Warning: DocumentRoot [/var/www/html/wordpress] does not exist
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
Syntax OK

2.4 Instalar WordPress desde navegador

Accediendo a <http://localhost/wp-admin/install.php> se completó la instalación gráfica de WordPress: se configuró el título del sitio 'WordPress Kali', se creó el usuario administrador wp_itmar y se finalizó la instalación exitosamente.



Hola

¡Este es el famoso proceso de instalación de WordPress en cinco minutos! Simplemente completa la información siguiente y estarás a punto de usar la más enriquecedora y potente plataforma de publicación personal del mundo.

Información necesaria

Por favor, proporciona la siguiente información. No te preocupes, siempre podrás cambiar estos ajustes más tarde.

Título del sitio

Nombre de usuario
Los nombres de usuario pueden tener únicamente caracteres alfanuméricos, espacios, guiones bajos, guiones medios, puntos y el símbolo @.

Contraseña [Ocultar](#)
Fuerte
Importante: Necesitas esta contraseña para acceder. Por favor, guárdala en un lugar seguro.

Tu correo electrónico
Comprueba bien tu dirección de correo electrónico antes de continuar.

Visibilidad en los motores de búsqueda ☒ Pedir a los motores de búsqueda que no indexen este sitio
Depende de los motores de búsqueda atender esta petición o no.

[Instalar WordPress](#)



¡Lo lograste!

WordPress ya está instalado. ¡Gracias, y que lo disfrutes!

Nombre de usuario wp_itmar

Contraseña La contraseña que has elegido.

[Acceder](#)

MÓDULO 2 — HARDENING WORDPRESS

2.1 Firewall UFW

Se habilitó el firewall UFW con políticas de denegación predeterminada para tráfico entrante y permisividad para saliente. Se abrieron únicamente los puertos necesarios: SSH (22), HTTP (80) y HTTPS (443).

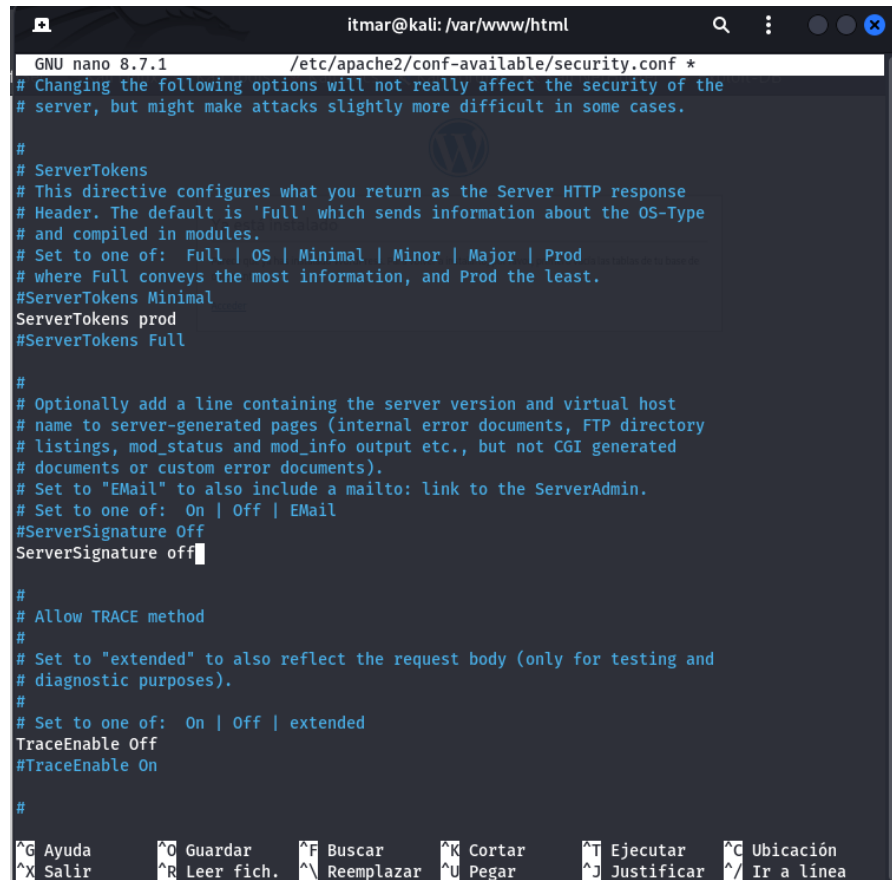
```
(itmar@kali)-[/var/www/html]
$ sudo ufw enable
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow ssh
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
sudo ufw status verbose
Firewall is active and enabled on system startup
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
Rule added
Rule added (v6)
Skipping adding existing rule
Skipping adding existing rule (v6)
Skipping adding existing rule
Skipping adding existing rule (v6)
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), deny (routed)
New profiles: skip
```

To	Action	From
--	-----	----
80/tcp	ALLOW IN	Anywhere
443/tcp	ALLOW IN	Anywhere
22/tcp	ALLOW IN	Anywhere
80/tcp (v6)	ALLOW IN	Anywhere (v6)
443/tcp (v6)	ALLOW IN	Anywhere (v6)
22/tcp (v6)	ALLOW IN	Anywhere (v6)

2.2 Ocultar versión Apache

En /etc/apache2/conf-available/security.conf se configuró ServerTokens Prod y ServerSignature Off, lo que evita que Apache revele su versión exacta en los encabezados HTTP. Se deshabilitó también el método HTTP TRACE (TraceEnable Off).

```
(itmar@kali)-[/var/www/html]
$ sudo nano /etc/apache2/conf-available/security.conf
```



```
GNU nano 8.7.1 /etc/apache2/conf-available/security.conf *
# Changing the following options will not really affect the security of the
# server, but might make attacks slightly more difficult in some cases.

#
# ServerTokens
# This directive configures what you return as the Server HTTP response
# Header. The default is 'Full' which sends information about the OS-Type
# and compiled in modules.
# Set to one of: Full | OS | Minimal | Minor | Major | Prod
# where Full conveys the most information, and Prod the least.
#ServerTokens Minimal
ServerTokens prod
#ServerTokens Full

#
# Optionally add a line containing the server version and virtual host
# name to server-generated pages (internal error documents, FTP directory
# listings, mod_status and mod_info output etc., but not CGI generated
# documents or custom error documents).
# Set to "EMail" to also include a mailto: link to the ServerAdmin.
# Set to one of: On | Off | EMail
#ServerSignature Off
ServerSignature off

#
# Allow TRACE method
#
# Set to "extended" to also reflect the request body (only for testing and
# diagnostic purposes).
#
# Set to one of: On | Off | extended
TraceEnable Off
#TraceEnable On

#
^G Ayuda      ^O Guardar   ^F Buscar    ^K Cortar     ^T Ejecutar   ^C Ubicación
^X Salir      ^R Leer fich. ^E Reemplazar ^U Pegar      ^J Justificar ^_ Ir a línea
```

Reinicia:

```
(itmar@kali)-[/var/www/html]
$ sudo systemctl restart apache2
```

Verifica:

`curl -I http://localhost | grep Server`

Debe mostrar Apache sin versión.

```
(itmar@kali)-[/var/www/html]
$ curl -I http://localhost | grep Server
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           0     0    0     0         0      0      0     0
Server: Apache
```


2.3 Bloquear métodos HTTP peligrosos

Se añadió una directiva LimitExcept en el VirtualHost para permitir únicamente los métodos HTTP seguros (GET, POST, HEAD), bloqueando métodos como PUT, DELETE, TRACE, CONNECT y OPTIONS que pueden ser explotados por atacantes.

```
(itmar@kali)-[/var/www/html]
$ sudo nano /etc/apache2/sites-available/wordpress.conf
```

```
<LimitExcept GET POST HEAD>
    Deny from all
</LimitExcept>
</Directory>
```

```
GNU nano 8.7.1 /etc/apache2/sites-available/wordpress.conf *
<VirtualHost *:80>
    ServerName localhost
    DocumentRoot /var/www/html

    <Directory /var/www/html>
        Options -Indexes -FollowSymLinks
        AllowOverride All
        Require all granted

    <LimitExcept GET POST HEAD>
        Deny from all
    </LimitExcept>
</Directory>

    ErrorLog ${APACHE_LOG_DIR}/wordpress_error.log
    CustomLog ${APACHE_LOG_DIR}/wordpress_access.log combined
</VirtualHost>
```

Aplica:

```
(itmar@kali)-[/var/www/html]
$ sudo apache2ctl configtest
sudo systemctl restart apache2
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
Syntax OK
```

2.4 Proteger wp-config.php

Se añadió en el archivo .htaccess una directiva que deniega el acceso directo al archivo wp-config.php desde el navegador, evitando la exposición de credenciales de base de datos y claves secretas.

```
(itmar@kali)-[/var/www/html]
$ sudo nano /var/www/html/.htaccess

GNU nano 8.7.1 /var/www/html/.htaccess *

<Files wp-config.php>
  Order allow,deny
  Deny from all
</Files>

Options -Indexes
# BEGIN WordPress
# The directives (lines) between "BEGIN WordPress" and "END WordPress" are
# dynamically generated, and should only be modified via WordPress filters.
# Any changes to the directives between these markers will be overwritten.
# END WordPress
```

Reinicia Apache:

```
(itmar@kali)-[/var/www/html]
$ sudo systemctl restart apache2
```

2.5 Bloquear ejecución PHP en uploads

Se creó un archivo .htaccess en wp-content/uploads/ con una regla FilesMatch que deniega la ejecución de cualquier archivo PHP, previniendo ataques de webshell a través de archivos subidos maliciosamente.

```
(itmar@kali)-[/var/www/html]
$ sudo nano /var/www/html/wp-content/uploads/.htaccess

GNU nano 8.7.1 /var/www/html/wp-content/uploads/.htaccess *
<FilesMatch "\.php$">
  Order Allow,Deny
  Deny from all
</FilesMatch>
```

2.6 Bloquear xmlrpc.php

El archivo xmlrpc.php es frecuentemente abusado para ataques de fuerza bruta y DDoS amplificado. Se añadió una directiva .htaccess que deniega completamente el acceso a este archivo.

```
(itmar@kali)-[/var/www/html]  
$ sudo nano /var/www/html/.htaccess
```

```
<Files wp-config.php>  
Order allow,deny  
Deny from all  
</Files>
```

Options -Indexes

```
<Files xmlrpc.php>  
Order Allow,Deny  
Deny from all  
</Files>
```

Ya está instalado

Parece que ya has instalado WordPress. Para volver a instalarlo, por favor, primero vacía las tablas de la base de datos antiguas.

Reinicia:

```
(itmar@kali)-[/var/www/html]  
$ sudo systemctl restart apache2
```

2.7 Bloquear edición de plugins/temas desde WP-Admin

Se añadieron las constantes DISALLOW_FILE_EDIT => true y WP_DEBUG => false en wp-config.php. La primera deshabilita el editor de plugins y temas desde el panel de administración, reduciendo el riesgo en caso de compromiso de credenciales de admin.

```
/* That's all, stop editing! Happy publishing. */  
define('DISALLOW_FILE_EDIT', true);  
define('WP_DEBUG', false);
```

Modulo 3 MÓDULO SSL/TLS con OpenSSL

3.1 Verificar OpenSSL e instalar si es necesario

Se verificó que OpenSSL 3.6.1 ya estaba disponible en el sistema. Se instaló explícitamente para asegurar la versión más reciente.

```
(itmar@kali)-[/var/www/html]
$ openssl version
OpenSSL 3.6.1 27 Jan 2026 (Library: OpenSSL 3.6.1 27 Jan 2026)

(itmar@kali)-[/var/www/html]
$ sudo apt install -y openssl
openssl ya está en su versión más reciente (3.6.1-3).
fijado openssl como instalado manualmente.
Los paquetes indicados a continuación se instalaron de forma automática y ya no son necesari
os:
  libicu76      libjs-source-map  libunibreak6      openjdk-21-jre-headless
  libio-pty-perl  libsimdjson30    node-core-util-is  postgresql-common-dev
  libipc-run-perl  libsimdutf31     node-process-nextick-args  python3-pysnmp4
  libiptcddata0  libteamctl0      openjdk-21-jre
Utilice «sudo apt autoremove» para eliminarlos.

Resumen:
  Actualizando: 0, Instalando 0, Eliminando: 0, no actualizando: 62

(itmar@kali)-[/var/www/html]
$
```

3.2 Activar módulo SSL en Apache

Se activaron los módulos ssl y headers de Apache. El módulo headers es necesario para añadir encabezados de seguridad HTTP como HSTS, X-Frame-Options y X-XSS-Protection.

```
(itmar@kali)-[/var/www/html]
$ sudo a2enmod ssl
sudo a2enmod headers
sudo systemctl restart apache2
Considering dependency mime for ssl:
Module mime already enabled
Considering dependency socache_shmcb for ssl:
Enabling module socache_shmcb.
Enabling module ssl.
See /usr/share/doc/apache2/README.Debian.gz on how to configure SSL and create self-signed c
ertificates.
To activate the new configuration, you need to run:
  systemctl restart apache2
Enabling module headers.
To activate the new configuration, you need to run:
  systemctl restart apache2
```

3.3 Crear carpeta para el certificado

```
(itmar@kali)-[/var/www/html]  
$ sudo mkdir -p /etc/ssl/wordpress
```

3.4 Crear clave privada (KEY)

Se generó una clave privada RSA de 2048 bits almacenada en /etc/ssl/wordpress/wordpress.key. Se verificó la integridad de la clave con openssl rsa -check, obteniendo confirmación 'RSA key ok'.

```
(itmar@kali)-[/var/www/html]  
$ sudo openssl genrsa -out /etc/ssl/wordpress/wordpress.key 2048  
  
(itmar@kali)-[/var/www/html]  
$ sudo openssl rsa -in /etc/ssl/wordpress/wordpress.key -check  
RSA key ok  
writing RSA key  
-----BEGIN PRIVATE KEY-----  
MIIEvgIBADANBgkqhkiG9w0BAQEFAASCBAgEAAoIBAQCgVouziNV/QsFx  
IpjQ5DHSVZogTm05ycjLBm/8aLnARStmVJS2V/mALqDQkFldSZXez+Rp3NHbZb4  
i0Q5o+n7dPKdRZghl+PI5K0/qSpRSkaiL/xixN7MvC9qyeKxbL5+hkQE68hfskbv  
sKg6Ay90ubQD23MYPVo0ej85sEDW7unGr6KmgfWPCxFyCscwXBL64qYTtin8DsHH  
j5ZFECc+2+G68Fv0SL9vMVMLDeRFokm5QsZrRufyu8pp8dqM2dAwjdjFdlQJJLh  
3fjr5DPcBs7CqjxY48sJtnnCZYdsfVaQP37sztuOMKu/++Zx0jWG0uUwjdBoBr63  
P+9JBu9LAGMBAECggEAQ9VppCqjXIRTD7i520J3u4tgugNEHZs7en1+0lTaJTh+  
THxDMEPW+D6B5cr0K8358f6AHfCwksYgI1270Xkm3C+RgBQBQJcKb1peJHqp9qb  
OHnBts2gjxCcpPrFkBe4HhJSy5wv0SFUooQGf8H8DALs0gQEPS/6YzAm/jv7Z4Y  
/CLpZLB5AI+fH83RKSBE7PUL7ZB8S7TICCL2McuCTY2Vk3ilgQfL2X/6e9AlzaOD  
I7p7EcTIXutIbx142yaLKml7bcPovtFvkRaNmUUn6z55LAOF7I9H/gYqnn+k8077  
CwVJ1JJmm75KpI13gTSvmcsQHIN3SYn7iy5J/4o9gQKBgQDf2ii2g7Yj4ZLYR6eh  
YPs+mOR3bjujtP3LYmqHa81P1WLSMVz9ygOVb5FaMbYXHfG8A9g+WtC+obyWCp3  
JVvQIbiLDTf7rV4kowQz19deWCy+ONZHBQZLNhg5FX9BWoAZOEAKc3h0tUaDH7H/  
meeycpExe3pdEx+jxYcu2ewVgQKBgQC3XVByeczLxd590PYQbPt2iArjUB6y1aIL  
MWuz89LoaeY4vjV6SeXW0KKD/MM3Ke9CTU+1c+CsnH4cZqCK4Q/C4IYrHLAbUKn6  
5se42YFvUxtxzwJlf8Qc0p/ItE10SXZKJ5J10/GgQv1LlEoRQGikB513KTMJSj9L  
Pb0zFtbiywKBgQDGLWrU2rx4B0hTta2DPp0df/0c4J3oouTiqWZS6wuoiQbmkk  
J0pcfuqlvPxR6rE92LItxvTXvHqu/Gak3noB4Qxmd90TBiy7pB4Ezh4RVX5RUS2Q  
V/t3Nm6FrHkJTWtIXc8p95gBly1pEWbykm6/S0VogEr59hFtUdRNV4xfAQKBGgTa  
MDsmfu0KMNumqRBTwONq5AIuuRPHqL7bSc/KVcB7LqMbCzLdnkp7E4sb5QtCRzqC  
Z0r4FyTgITgPYB9VTvsXh8sQjhj33oeoM8s4qImZbvtDfZhl38suGj0bnLcgJL  
TaT9E7L/5W1CfJKMh04o0hWmVWnQqpm2nDXuY/aNAoGBAL0YRp2D10iXliipsniE  
icC2VMke19oy46rxYci/Vk3uJyK2Htrg27FDzx6iUvjZtYPneqxCVmDdYnGHcgVH  
/ut5w45raQvzuT8w+FIuWD4d0cBLHp+F0SMm8GcrZnuN8YvVfR+nTob8ekPEzt3k  
j66rtKV88otplZvBnSLzM35z  
-----END PRIVATE KEY-----
```

3.5 Crear CSR (solicitud de certificado)

Se generó un Certificate Signing Request (CSR) con metadatos de identificación: País PA, Estado Panama, Localidad Panama City, Organización Laboratorio, Unidad Seguridad Web. A partir del CSR se creó el certificado autofirmado con validez de 365 días.

```
(itmar@kali)-[/var/www/html]
$ sudo openssl req -new \
-key /etc/ssl/wordpress/wordpress.key \
-out /etc/ssl/wordpress/wordpress.csr \
-subj "/C=PA/ST=Panama/L=Panama City/O=Laboratorio/OU=Seguridad Web/CN=localhost"
```

3.6 Crear certificado autofirmado (CRT)

```
(itmar@kali)-[/var/www/html]
$ sudo openssl x509 -req \
-days 365 \
-in /etc/ssl/wordpress/wordpress.csr \
-signkey /etc/ssl/wordpress/wordpress.key \
-out /etc/ssl/wordpress/wordpress.crt
Certificate request self-signature ok
subject=C=PA, ST=Panama, L=Panama City, O=Laboratorio, OU=Seguridad Web, CN=localhost
```

```
(itmar@kali)-[/var/www/html]
$ sudo openssl x509 -in /etc/ssl/wordpress/wordpress.crt -text -noout
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            11:ad:90:07:8c:cd:6a:8b:29:c0:c6:ca:4e:6e:f5:5e:01:23:93:91
        Signature Algorithm: sha256WithRSAEncryption
        Issuer: C=PA, ST=Panama, L=Panama City, O=Laboratorio, OU=Seguridad Web, CN=localhost
    Validity
        Not Before: May  5 21:15:43 2026 GMT
        Not After : May  5 21:15:43 2027 GMT
        Subject: C=PA, ST=Panama, L=Panama City, O=Laboratorio, OU=Seguridad Web, CN=localhost
    Subject Public Key Info:
        Public Key Algorithm: rsaEncryption
        Public-Key: (2048 bit)
        Modulus:
            00:a0:56:8b:b3:88:d5:7f:42:c1:71:22:98:d0:e4:
            31:d2:55:9a:20:4e:6d:39:c9:c8:cb:06:6f:fc:68:
            b9:c0:45:2b:66:54:94:b6:57:f9:80:2e:a0:d0:90:
            59:5d:49:94:97:7b:3f:91:a7:73:47:6d:96:f8:8b:
            44:39:a3:e9:fb:74:f2:9d:45:98:21:97:e3:c8:e4:
            ad:3f:a9:2a:51:4a:46:a2:2f:fc:62:c4:de:cc:bc:
            2f:6a:c9:e2:b1:6c:be:7e:86:44:04:eb:c8:5f:b2:
            46:ef:b0:a8:3a:03:2f:4e:b9:b4:03:db:73:18:3d:
            5a:34:7a:3f:39:b0:40:d6:ee:e9:c6:af:a2:a6:81:
            f5:8f:0b:11:72:0a:c7:30:5c:12:fa:e2:a6:13:b6:
            29:fc:0e:c1:c7:8f:96:5f:10:27:3e:db:e1:ba:f0:
            5b:ce:4a:51:3d:bc:c5:4c:2c:37:91:16:89:26:e5:
            0b:19:ad:1b:9f:ca:ef:29:a7:c7:6a:33:67:40:c2:
            37:63:15:d9:50:24:92:e1:dd:f8:eb:e4:33:c2:06:
            ce:c2:aa:3c:58:e3:cb:09:b6:79:c2:65:87:6c:7d:
            56:90:3f:7e:ec:ce:db:8e:30:ab:bf:fb:e6:71:3a:
            35:86:d2:e5:30:8d:d6:e8:06:be:b7:3f:ef:49:06:
            ef:4b
        Exponent: 65537 (0x10001)
```

3.7 Permisos correctos del certificado

Se configuraron permisos restrictivos: 600 para la clave privada (solo root puede leerla) y 644 para el certificado público. El propietario se estableció como root:root para mayor seguridad.

```
(itmar@kali)-[/var/www/html]
$ sudo chmod 600 /etc/ssl/wordpress/wordpress.key
sudo chmod 644 /etc/ssl/wordpress/wordpress.crt
sudo chown root:root /etc/ssl/wordpress/wordpress.*

(itmar@kali)-[/var/www/html]
$
```

3.8 Crear VirtualHost HTTPS

Se creó el VirtualHost HTTPS en el puerto 443 con las directivas SSL apuntando a los archivos de certificado. Se configuraron encabezados de seguridad HTTP: X-Content-Type-Options, X-Frame-Options (SAMEORIGIN), X-XSS-Protection y Strict-Transport-Security (HSTS) con max-age de 31,536,000 segundos (1 año).

El VirtualHost HTTP original se convirtió en un redirector permanente (301) hacia HTTPS, asegurando que todo el tráfico viaje cifrado.

```
(itmar@kali)-[/var/www/html]
$ sudo nano /etc/apache2/sites-available/wordpress-ssl.conf
```

```
GNU nano 8.7.1 /etc/apache2/sites-available/wordpress-ssl.conf *
<VirtualHost *:443>
    ServerName localhost
    DocumentRoot /var/www/html

    SSLEngine on
    SSLCertificateFile /etc/ssl/wordpress/wordpress.crt
    SSLCertificateKeyFile /etc/ssl/wordpress/wordpress.key

    SSLProtocol all -SSLv3 -TLSv1 -TLSv1.1

    Header always set X-Content-Type-Options "nosniff"
    Header always set X-Frame-Options "SAMEORIGIN"
    Header always set X-XSS-Protection "1; mode=block"
    Header always set Strict-Transport-Security "max-age=31536000"

    <Directory /var/www/html>
        AllowOverride All
        Require all granted
    </Directory>

    ErrorLog ${APACHE_LOG_DIR}/wordpress_ssl_error.log
    CustomLog ${APACHE_LOG_DIR}/wordpress_ssl_access.log combined
</VirtualHost>
```


3.9 Activar el sitio SSL

```
(itmar@kali)-[/var/www/html]
$ sudo a2ensite wordpress-ssl.conf
sudo apache2ctl configtest
sudo systemctl restart apache2
Enabling site wordpress-ssl.
To activate the new configuration, you need to run:
    systemctl reload apache2
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
Syntax OK
```

3.1.0 Redirigir HTTP → HTTPS

```
(itmar@kali)-[/var/www/html]
$ sudo nano /etc/apache2/sites-available/wordpress.conf
```

```
GNU nano 8.7.1 /etc/apache2/sites-available/wordpress.conf
1<VirtualHost *:80>
#   ServerName localhost
#   DocumentRoot /var/www/html
#
#   <#Directory /var/www/html>
#       Options -Indexes -FollowSymLinks
#       AllowOverride All
#       Require all granted
#
#   #<LimitExcept GET POST HEAD>
#       ##       Deny from all
#   </LimitExcept>
#   </Directory>
#
#   ErrorLog ${APACHE_LOG_DIR}/wordpress_error.log
#   CustomLog ${APACHE_LOG_DIR}/wordpress_access.log combined
#</VirtualHost>

<VirtualHost *:80>
    ServerName localhost
    Redirect permanent / https://localhost/
</VirtualHost>
```

Reiniciar:

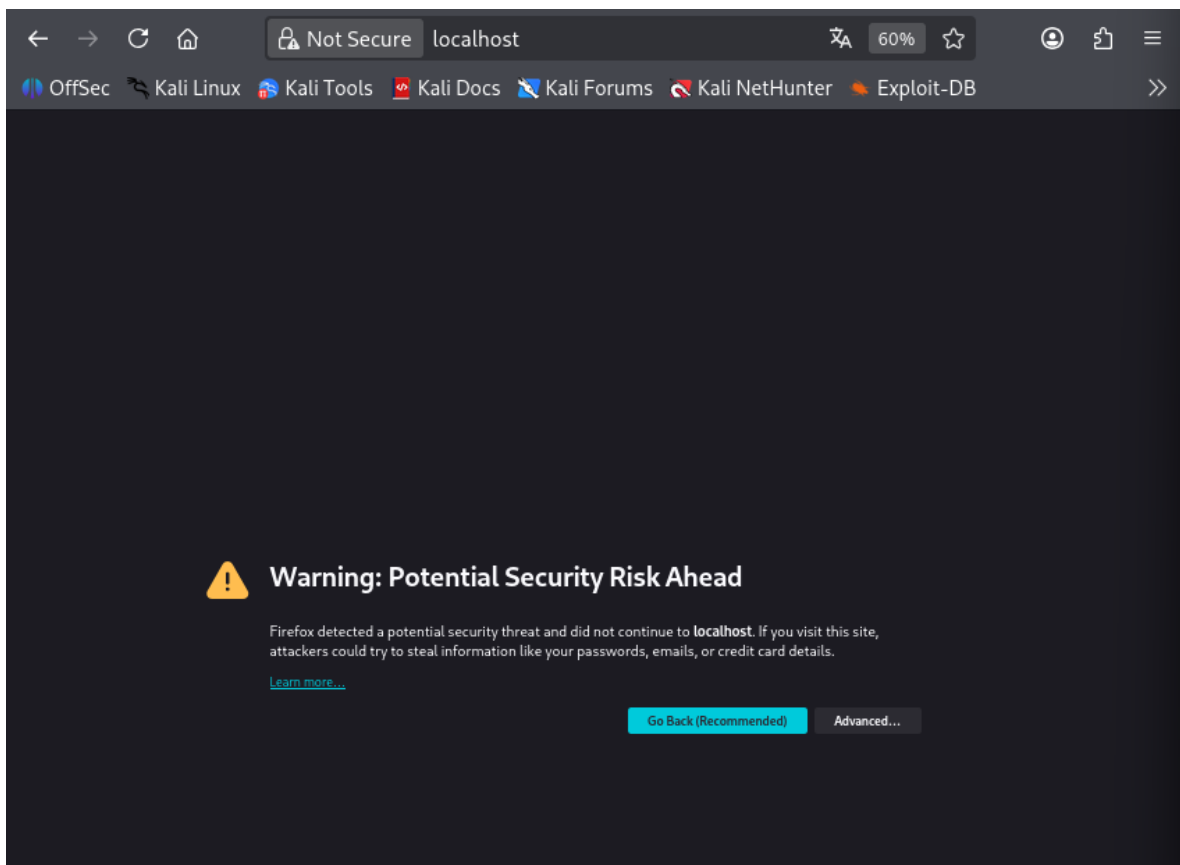
```
(itmar@kali)-[/var/www/html]
$ sudo apache2ctl configtest
sudo systemctl restart apache2
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
Syntax OK
```

3.1.1 Verificar que HTTPS funciona

Se verificó el funcionamiento con `curl -k -I https://localhost`, obteniendo respuesta HTTP/1.1 200 OK con todos los encabezados de seguridad presentes. Se confirmó también con `openssl s_client -connect localhost:443`, mostrando la cadena de certificado completa con algoritmo sha256WithRSAEncryption.

```
(itmar@kali)-[/var/www/html]
$ curl -k -I https://localhost
HTTP/1.1 200 OK
Date: Tue, 05 May 2026 21:28:45 GMT
Server: Apache
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
Strict-Transport-Security: max-age=31536000
Link: <https://localhost/index.php?rest_route=/>; rel="https://api.w.org/"
Content-Type: text/html; charset=UTF-8
```

3.1.2 Probar desde navegador



localhost uses an invalid security certificate.

The certificate is not trusted because it is self-signed.

Error code: [MOZILLA_PKIX_ERROR_SELF_SIGNED_CERT](#)

[View Certificate](#)

[Go Back \(Recommended\)](#)

[Accept the Risk and Continue](#)

WordPress Kali

Página de ejemplo

Blog

¡Hola, mundo!

Te damos la bienvenida a WordPress. Esta es tu primera entrada. Edítala o bórrala, ¡luego empieza a escribir!

5 de mayo de 2020

WordPress Kali

[Blog](#)

[Eventos](#)

[Acerca de](#)

[Tienda](#)

[FAQs](#)

[Patrones](#)

[Autores](#)

[Temas](#)

Twenty Twenty-Five

Diseñado con [WordPress](#)

3.1.3 PRUEBA FINAL DEL CERTIFICADO (OPENSSL)

```
(itmar@kali)-[/var/www/html]
$ openssl s_client -connect localhost:443
Connecting to ::1
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 C=PA, ST=Panama, L=Panama City, O=Laboratorio, OU=Seguridad Web, CN=localhost
verify error:num=18:self-signed certificate
verify return:1
depth=0 C=PA, ST=Panama, L=Panama City, O=Laboratorio, OU=Seguridad Web, CN=localhost
verify return:1
---
Certificate chain
 0 s:C=PA, ST=Panama, L=Panama City, O=Laboratorio, OU=Seguridad Web, CN=localhost
  i:C=PA, ST=Panama, L=Panama City, O=Laboratorio, OU=Seguridad Web, CN=localhost
  a:PKEY: RSA, 2048 (bit); sigalg: sha256WithRSAEncryption
  v:NotBefore: May  5 21:15:43 2026 GMT; NotAfter: May  5 21:15:43 2027 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIDmzCCAoGAwIBAGIUEa2QB4zNaospwMbKTM71XgEjk5EwDQYJKoZIhvcNAQEL
BQAwZjELMAkGA1UEBhMCUEExDzANBgNVBAGMB1BhbmcFtYTEUMBIGA1UEBwwLUGFu
YW1hIENpdHkxZDASBgNVBAoMC0xhYm9yYXRvcmlvMRYwFAYDVQQLEA1TZWd1cm1k
YWQgV2ViMRIwEAYDVQQDDA1sb2NhbgHvc3QwHhcNMjYwNTA1MjExNTQzWhcNMjcw
NTA1MjExNTQzWjB2MQswCQYDVQQGEwJQTEPMA0GA1UECAwGUGFuYW1hMRQwEgYD
VQQHDA1QYw5hbWEGQ2l0eTEUMBIGA1UECgwLTGFib3JhdG9yaW8xZjAUBgNVBAsM
DVNlZ3VyaWRhZCBXZWlxeEjAQBgnNVBAMMCWxvY2FsaG9zdDCCASIwDQYJKoZIhvcN
AQEBBQADggEPADCCAQoCggEBABKi7OI1X9CwXEimNDkMdJVmiB0bTnJyMsGb/xo
ucBFK2ZULZX+YAuoNCQWV1JlJd7P5Gnc0dtlviLRDmj6ft08p1FmCGX48jkrT+p
KLfKRqIv/GLE3sy8L2rJ4rFsvn6GRATryF+yRu+wqDoDL065tAPbcxg9WjR6Pzmm
QNbu6cavoqa89Y8LEXIKxzBcEvriph02KfW0wcePll8QJz7b4brwW85KUT28xUws
N5EWiSblCxmTG5/K7ymnx2ozZ0DCN2MV2VAKkuHd+OvkM8IGzsKqPFjjywm2ecJl
h2x9VpA/fuz0244wq7/75nE6NYbS5TCN1ugGvrc/70kG70sCAwEAAAMhMB8wHQYD
VR00BBYEFKaZSqSUjVXW38i+ayYqqq7lQkp2MA0GCSqGSIb3DQEBCwUAA4IBAQBK
9iv03uR0jR0cDWT43uCovoQp/Mcx7VF3oMwQ6KH9zP0HSnBum4bzir2jQmQhWr3z
H5oJV0Yu4w0XMJSzYrym8igJ0UngeoStLLEb2Jui5X2l7YkyotARNnups+8GKtlu
CwsDLq7dYugEsHbF1tTEF45XmrQbnb4TTgXdT6RS8a0qJpfGs0o5MBwZ0Gk3TAXg
B8ue3vEH5EA1cehog8LzV1KUJffSTdgrX99303uyAk8KnYBwkKq6HHI9mw6N6O
OA3s5Y2F08hsbGH2LHT/xcz6gICbW1pUPbhN0PG5yqAdMPiHRtYpOzq1vQZ0aSm
eobu7eHcXo1Krrf+HMXO
-----END CERTIFICATE-----
```

Modulo 4 WAF con ModSecurity

4.1 Instalar ModSecurity

Se instaló libapache2-mod-security2 junto con sus dependencias (liblua5.1 y modsecurity-crs). Se verificó que el módulo security2_module quedó correctamente cargado en Apache mediante apachectl -M.

```
(itmar@kali)-[/var/www/html]
└─$ sudo apt install -y libapache2-mod-security2
Los paquetes indicados a continuación se instalaron de forma automática y ya no son necesarios:
  libicu76      libjs-source-map  libunibreak6      openjdk-21-jre-headless
  libio-pty-perl  libsimdjson30    node-core-util-is  postgresql-common-dev
  libipc-run-perl  libsimdutf31     node-process-nextick-args  python3-pysnmp4
  libiptcdata0    libteamctl0      openjdk-21-jre
Utilice «sudo apt autoremove» para eliminarlos.

Instalando:
  libapache2-mod-security2

Instalando dependencias:
  liblua5.1-0 modsecurity-crs

Paquetes sugeridos:
  lua geoip-database-contrib python

Resumen:
  Actualizando: 0, Instalando 3, Eliminando: 0, no actualizando: 62
  Tamaño de la descarga: 541 kB
  Espacio necesario: 2,482 kB / 19.2 GB disponible

Des:1 http://kali.download/kali kali-rolling/main amd64 liblua5.1-0 amd64 5.1.5-12 [112 kB]
Des:2 http://mirror.us.cdn-perfprod.com/kali kali-rolling/main amd64 libapache2-mod-security2 amd64 2.9.12-2 [265 kB]
Des:3 http://kali.download/kali kali-rolling/main amd64 modsecurity-crs all 3.3.9-1 [164 kB]
Descargados 541 kB en 1s (431 kB/s)
Seleccionando el paquete liblua5.1-0:amd64 previamente no seleccionado.
(Leyendo la base de datos ... 504668 ficheros o directorios instalados actualmente.)
Preparando para desempaquetar .../liblua5.1-0_5.1.5-12_amd64.deb ...
Desempaquetando liblua5.1-0:amd64 (5.1.5-12) ...
Seleccionando el paquete libapache2-mod-security2 previamente no seleccionado.
Preparando para desempaquetar .../libapache2-mod-security2_2.9.12-2_amd64.deb ...
Desempaquetando libapache2-mod-security2 (2.9.12-2) ...
Seleccionando el paquete modsecurity-crs previamente no seleccionado.
Preparando para desempaquetar .../modsecurity-crs_3.3.9-1_all.deb ...
Desempaquetando modsecurity-crs (3.3.9-1) ...
```

Verifica que está cargado:

Debe salir algo como:

security2_module (shared)

```
(itmar@kali)-[/var/www/html]
└─$ sudo apachectl -M | grep security
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
security2_module (shared)
```

4.2 Activar ModSecurity en modo BLOQUEO

Se copió el archivo de configuración recomendado y se editó para establecer SecRuleEngine On (modo activo de bloqueo, en lugar del modo DetectionOnly). Se configuró el log de auditoría en /var/log/apache2/modsec_audit.log.

Copia configuración recomendada:

```
(itmar@kali)-[/var/www/html]
$ sudo cp /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf
(itmar@kali)-[/var/www/html]
$
```

Edita archivo:

```
GNU nano 8.7.1 /etc/modsecurity/modsecurity.conf *
# -- Rule engine initialization -----
# Enable ModSecurity, attaching it to every transaction. Use detection
# only to start with, because that minimises the chances of post-installation
# disruption.
#
SecRuleEngine on

# Use a single file for logging. This is much easier to
# assumes that you will use the audit log only occasionally
#
SecAuditLogType Serial
SecAuditLog /var/log/apache2/modsec_audit.log
```

4.3 Reiniciar Apache para aplicar ModSecurity

```
(itmar@kali)-[/var/www/html]
$ sudo apache2ctl configtest
sudo systemctl restart apache2
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
Syntax OK
```

4.4 Instalar OWASP CRS (Core Rule Set)

Se descargó el OWASP CRS v3.3.5 desde GitHub, se descomprimió y se ubicó en /etc/modsecurity/crs/. Se copió el archivo de configuración base crs-setup.conf.example como crs-setup.conf.

Nos movemos a /tmp:

```
(itmar@kali)-[/var/www/html]
$ cd /tmp
```

Descarga CRS:

```
(itmar@kali)-[/tmp]
$ wget https://github.com/coreruleset/coreruleset/archive/refs/tags/v3.3.5.tar.gz
--2026-05-05 16:51:15-- https://github.com/coreruleset/coreruleset/archive/refs/tags/v3.3.5
.tar.gz
Resolviendo github.com (github.com)... 140.82.112.3
Conectando con github.com (github.com)[140.82.112.3]:443... conectado.
Petición HTTP enviada, esperando respuesta... 302 Found
Localización: https://codeload.github.com/coreruleset/coreruleset/tar.gz/refs/tags/v3.3.5 [s
iguiendo]
--2026-05-05 16:51:16-- https://codeload.github.com/coreruleset/coreruleset/tar.gz/refs/tag
s/v3.3.5
Resolviendo codeload.github.com (codeload.github.com)... 140.82.112.10
Conectando con codeload.github.com (codeload.github.com)[140.82.112.10]:443... conectado.
Petición HTTP enviada, esperando respuesta... 200 OK
Longitud: no especificado [application/x-gzip]
Grabando a: «v3.3.5.tar.gz»

v3.3.5.tar.gz          [  <=>          ] 292.44K  377KB/s  en 0.8s

2026-05-05 16:51:17 (377 KB/s) - «v3.3.5.tar.gz» guardado [299458]
```

Descomprime:

```
(itmar@kali)-[/tmp]
$ cd /tmp
tar -xzf v3.3.5.tar.gz

(itmar@kali)-[/tmp]
$ ls -la /tmp | grep core
drwxrwxr-x 7 itmar itmar 440 jul 21 2023 coreruleset-3.3.5
```

Mueve CRS a /etc/modsecurity:

```
(itmar@kali)-[/tmp]
$ sudo mv coreruleset-3.3.5 /etc/modsecurity/crs
```

Copia archivo de configuración base:

```
(itmar@kali)-[/tmp]
$ sudo cp /etc/modsecurity/crs/crs-setup.conf.example /etc/modsecurity/crs/crs-setup.conf
```


4.5 Activar CRS dentro de Apache

Se editó /etc/apache2/mods-enabled/security2.conf para incluir las reglas del CRS. Se añadieron las directivas Include para el archivo de setup y todos los archivos de reglas (rules/*.conf). Se creó el directorio de caché /var/cache/modsecurity con propietario www-data.

```
(itmar@kali)-[/tmp]
$ sudo nano /etc/apache2/mods-enabled/security2.conf

GNU nano 8.7.1 /etc/apache2/mods-enabled/security2.conf
<IfModule security2_module>
  SecDataDir /var/cache/modsecurity
  IncludeOptional /etc/modsecurity/*.conf
  Include /etc/modsecurity/crs/crs-setup.conf
  Include /etc/modsecurity/crs/rules/*.conf
</IfModule>
```

4.6 Crear carpeta de cache de ModSecurity

```
(itmar@kali)-[/tmp]
$ sudo mkdir -p /var/cache/modsecurity
sudo chown www-data:www-data /var/cache/modsecurity

(itmar@kali)-[/tmp]
$
```

Reiniciar apache:

```
(itmar@kali)-[/tmp]
$ sudo apache2ctl configtest
sudo systemctl restart apache2
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
Syntax OK
```

4.7 Verificar que CRS cargó sin errores

Mira errores Apache:

```
(itmar@kali)-[/tmp]
$ sudo tail -50 /var/log/apache2/error.log
[Tue May 05 16:27:23.357602 2026] [mpm_prefork:notice] [pid 243815:tid 243815] AH00163: Apache/2.4.66 (Debian) OpenSSL/3.6.1 configured -- resuming normal operations
[Tue May 05 16:27:23.357667 2026] [core:notice] [pid 243815:tid 243815] AH00094: Command line: '/usr/sbin/apache2 -D FOREGROUND'
[Tue May 05 16:36:15.272810 2026] [mpm_prefork:notice] [pid 243815:tid 243815] AH00170: caught SIGWINCH, shutting down gracefully
[Tue May 05 16:36:15.479142 2026] [security2:notice] [pid 247477:tid 247477] ModSecurity for Apache/2.9.12 (http://www.modsecurity.org/) configured.
[Tue May 05 16:36:15.479200 2026] [security2:notice] [pid 247477:tid 247477] ModSecurity: APR compiled version="1.7.5"; loaded version="1.7.6"
[Tue May 05 16:36:15.479203 2026] [security2:warn] [pid 247477:tid 247477] ModSecurity: Loaded APR do not match with compiled!
[Tue May 05 16:36:15.479205 2026] [security2:notice] [pid 247477:tid 247477] ModSecurity: PCRE2 compiled version="10.46 "; loaded version="10.46 2025-08-27"
[Tue May 05 16:36:15.479206 2026] [security2:notice] [pid 247477:tid 247477] ModSecurity: LuaA compiled version="Lua 5.1"
[Tue May 05 16:36:15.479208 2026] [security2:notice] [pid 247477:tid 247477] ModSecurity: YAJL compiled version="2.1.0"
[Tue May 05 16:36:15.479210 2026] [security2:notice] [pid 247477:tid 247477] ModSecurity: LIBXML compiled version="2.14.5"
[Tue May 05 16:36:15.479211 2026] [security2:notice] [pid 247477:tid 247477] ModSecurity: Status engine is currently disabled, enable it by set SecStatusEngine to On.
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
mpmprotect() failed [13] Permission denied
mpmprotect() failed [13] Permission denied
mpmprotect() failed [13] Permission denied
mpmprotect() failed [13] Permission denied
[Tue May 05 16:36:15.563683 2026] [mpm_prefork:notice] [pid 247477:tid 247477] AH00163: Apache/2.4.66 (Debian) OpenSSL/3.6.1 configured -- resuming normal operations
[Tue May 05 16:36:15.563866 2026] [core:notice] [pid 247477:tid 247477] AH00094: Command line: '/usr/sbin/apache2 -D FOREGROUND'
[Tue May 05 16:44:45.773873 2026] [mpm_prefork:notice] [pid 247477:tid 247477] AH00170: caught SIGWINCH, shutting down gracefully
[Tue May 05 16:44:45.991573 2026] [security2:notice] [pid 250758:tid 250758] ModSecurity for Apache/2.9.12 (http://www.modsecurity.org/) configured.
```

5. MÓDULO PRUEBAS DE ATAQUES CONTROLADOS (EVIDENCIA)

5.1 Prueba XSS (debe bloquear)

Se realizó una solicitud HTTP con un payload XSS clásico embebido en un parámetro GET. ModSecurity detectó el patrón malicioso y devolvió un código 403 Forbidden, bloqueando el ataque exitosamente.

```
(itmar@kali)-[/tmp]
$ curl -k -s -o /dev/null -w "%{http_code}\n" \
"https://localhost/?test=<script>alert(1)</script>"
403
```

5.2 Prueba Path Traversal (debe bloquear)

Se intentó acceder al archivo /etc/passwd del sistema mediante una técnica de traversal de directorios en el parámetro file. ModSecurity identificó el patrón ../../ característico de este ataque y retornó 403 Forbidden.

```
(itmar@kali)-[/tmp]
$ curl -k -s -o /dev/null -w "%{http_code}\n" \
"https://localhost/?file=../../etc/passwd"
403
```

5.3 Ver evidencia en logs ModSecurity

El log de auditoría `/var/log/apache2/modsec_audit.log` registró ambos ataques con nivel de severidad **CRITICAL**, identificando las reglas OWASP CRS activadas:

```

(itmar@kali)-[/tmp]
└─$ sudo tail -50 /var/log/apache2/modsec_audit.log

--460e510b-F--
HTTP/1.1 403 Forbidden
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
Strict-Transport-Security: max-age=31536000
Content-Length: 239
Content-Type: text/html; charset=iso-8859-1

--460e510b-E--
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
</body></html>

--460e510b-H--
Message: Warning. Pattern match "(?i)(?:\\x5c(?:?:c(?:?:0%?(?:2a|f|5c|9v)|1%?:[19p]|c|8s|a|f)|2(?:?:5(?:?:c(?:?:0%25af|1%259c)|2f|5c)|%46|f)|(?:?:f(?:?:8%8)?%08|e)%080%a|bg%q)f|%3(?:?:2(?:?:%?:%6|4|6|f)|5%?%63)|u(?:?:221|56)|002f|EFC8|F025)|1u|5c)|0x(?:?:2f|5c)|\\V\\V\\V)(?:%?:f(?:?:c(?:?:c%80|8)%8)?%08 ..." at REQUEST_URI_RAW. [file "/etc/modsecurity/crs/rules/REQUEST-930-APPLICATION-ATTACK-LFI.conf"] [line "48"] [id "930100"] [msg "Path Traversal Attack (../)"] [data "Matched Data: ../ found within REQUEST_URI_RAW: ?file=.././etc/passwd"] [severity "CRITICAL"] [ver "OWASP CRS/3.3.5"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-lfi"] [tag "paranoia-level/1"] [tag "OWASP CRS"] [tag "capec/1000/255/153/126"]
Message: Warning. Pattern match "(?i)(?:\\x5c(?:?:c(?:?:0%?(?:2a|f|5c|9v)|1%?:[19p]|c|8s|a|f)|2(?:?:5(?:?:c(?:?:0%25af|1%259c)|2f|5c)|%46|f)|(?:?:f(?:?:8%8)?%08|e)%080%a|bg%q)f|%3(?:?:2(?:?:%?:%6|4|6|f)|5%?%63)|u(?:?:221|56)|002f|EFC8|F025)|1u|5c)|0x(?:?:2f|5c)|\\V\\V\\V)(?:%?:f(?:?:c(?:?:c%80|8)%8)?%08 ..." at ARGS:file. [file "/etc/modsecurity/crs/rules/REQUEST-930-APPLICATION-ATTACK-LFI.conf"] [line "48"] [id "930100"] [msg "Path Traversal Attack (../)"] [data "Matched Data: ../ found within ARGS:file: .././etc/passwd"] [severity "CRITICAL"] [ver "OWASP CRS/3.3.5"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-lfi"] [tag "paranoia-level/1"] [tag "OWASP CRS"] [tag "capec/1000/255/153/126"]

Message: Warning. Pattern match "(?:^[\\V\\V\\V\\.\\V(?:[\\V\\V])$)" at REQUEST_URI. [file "/etc/modsecurity/crs/rules/REQUEST-930-APPLICATION-ATTACK-LFI.conf"] [line "72"] [id "930110"] [msg "Path Traversal Attack (../)"] [data "Matched Data: ../ found within REQUEST_URI: ?file=.././etc/passwd"] [severity "CRITICAL"] [ver "OWASP CRS/3.3.5"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-lfi"] [tag "paranoia-level/1"] [tag "OWASP CRS"] [tag "capec/1000/255/153/126"]
Message: Warning. Pattern match "(?:^[\\V\\V\\V\\.\\V(?:[\\V\\V])$)" at REQUEST_URI. [file "/etc/modsecurity/crs/rules/REQUEST-930-APPLICATION-ATTACK-LFI.conf"] [line "72"] [id "930110"] [msg "Path Traversal Attack (../)"] [data "Matched Data: ../ found within REQUEST_URI: ?file=.././etc/passwd"] [severity "CRITICAL"] [ver "OWASP CRS/3.3.5"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-lfi"] [tag "paranoia-level/1"] [tag "OWASP CRS"] [tag "capec/1000/255/153/126"]
Message: Warning. Pattern match "(?:^[\\V\\V\\V\\.\\V(?:[\\V\\V])$)" at ARGS:file. [file "/etc/modsecurity/crs/rules/REQUEST-930-APPLICATION-ATTACK-LFI.conf"] [line "72"] [id "930110"] [msg "Path Traversal Attack (../)"] [data "Matched Data: ../ found within ARGS:file: .././etc/passwd"] [severity "CRITICAL"] [ver "OWASP CRS/3.3.5"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-lfi"] [tag "paranoia-level/1"] [tag "OWASP CRS"] [tag "capec/1000/255/153/126"]
Message: Warning. Pattern match "(?:^[\\V\\V\\V\\.\\V(?:[\\V\\V])$)" at ARGS:file. [file "/etc/modsecurity/crs/rules/REQUEST-930-APPLICATION-ATTACK-LFI.conf"] [line "72"] [id "930110"] [msg "Path Traversal Attack (../)"] [data "Matched Data: ../ found within ARGS:file: .././etc/passwd"] [severity "CRITICAL"] [ver "OWASP CRS/3.3.5"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-lfi"] [tag "paranoia-level/1"] [tag "OWASP CRS"] [tag "capec/1000/255/153/126"]
Message: Warning. Matched phrase "etc/passwd" at ARGS:file. [file "/etc/modsecurity/crs/rules/REQUEST-930-APPLICATION-ATTACK-LFI.conf"] [line "98"] [id "930120"] [msg "OS File Access Attempt"] [data "Matched Data: etc/passwd found within ARGS:file: .././etc/passwd"] [severity "CRITICAL"] [ver "OWASP CRS/3.3.5"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-lfi"] [tag "paranoia-level/1"] [tag "OWASP CRS"] [tag "capec/1000/255/153/126"] [tag "PCI/6.5.4"]
Message: Warning. Matched phrase "etc/passwd" at ARGS:file. [file "/etc/modsecurity/crs/rules/REQUEST-932-APPLICATION-ATTACK-RCE.conf"] [line "501"] [id "932160"] [msg "Remote Command Execution: Unix Shell Code Found"] [data "Matched Data: etc/passwd found within ARGS:file: .././etc/passwd"] [severity "CRITICAL"] [ver "OWASP CRS/3.3.5"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-lfi"] [tag "paranoia-level/1"] [tag "OWASP CRS"] [tag "capec/1000/152/248/88"] [tag "PCI/6.5.2"]
Message: Access denied with code 403 (phase 2). Operator GE matched 5 at TX:anomaly_score. [file "/etc/modsecurity/crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf"] [line "94"] [id "949110"] [msg "Inbound Anomaly Score Exceeded (Total Score: 40)"] [severity "CRITICAL"] [ver "OWASP CRS"] [tag "capec/1000/255/153/126"]

```

6. MÓDULO FINAL — CHECKLIST COMPLETA DE ENTREGA

```
(itmar@kali)-[/tmp]
$ sudo systemctl status apache2 mariadb | grep -E "Active|●"
sudo ufw status verbose
curl -I http://localhost | grep Location
curl -k -I https://localhost | grep -E "Strict|X-Frame|X-Content|X-XSS"
sudo apachectl -M | grep security
curl -k -s -o /dev/null -w "Código HTTP: %{http_code}\n" \
"https://localhost/?test=<script>alert(1)</script>"
● apache2.service - The Apache HTTP Server
   Active: active (running) since Tue 2026-05-05 17:22:13 EST; 20s ago
● mariadb.service - MariaDB 11.8.6 database server
   Active: active (running) since Tue 2026-05-05 12:50:10 EST; 4h 32min ago
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), deny (routed)
New profiles: skip

To Action From
--
80/tcp ALLOW IN Anywhere
443/tcp ALLOW IN Anywhere
22/tcp ALLOW IN Anywhere
80/tcp (v6) ALLOW IN Anywhere (v6)
443/tcp (v6) ALLOW IN Anywhere (v6)
22/tcp (v6) ALLOW IN Anywhere (v6)

% Total % Received % Xferd Average Speed Time Time Time Current
0 0 0 0 0 0 0 0
Location: https://localhost/
% Total % Received % Xferd Average Speed Time Time Time Current
0 0 0 0 0 0 0 0
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
Strict-Transport-Security: max-age=31536000
security2_module (shared)
Código HTTP: 403

(itmar@kali)-[/tmp]
$
```

RESULTADOS QUE TE DEBEN SALIR

- Apache activo
- MariaDB activo
- Firewall activo
- HTTP redirige a HTTPS
- HTTPS responde con headers
- ModSecurity activo
- Ataque XSS devuelve 403
- Log modsec_audit.log muestra el bloqueo

CONCLUSIÓN

La realización de este laboratorio nos permitió consolidar conocimientos fundamentales en la instalación y aseguramiento de infraestructuras web en entornos Linux. A lo largo de los seis módulos desarrollados, se implementó exitosamente una arquitectura de seguridad en capas que protege un servidor WordPress desde múltiples vectores de ataque.

La instalación del stack LAMP demostró la importancia de seguir procedimientos ordenados: actualizar el sistema antes de instalar componentes, configurar bases de datos con usuarios de privilegio mínimo, y establecer los permisos de archivos correctos desde el inicio. Estas prácticas básicas evitan vulnerabilidades comunes en configuraciones descuidadas.

El módulo de hardening evidenció que la seguridad de una aplicación web va más allá del software instalado: requiere configuraciones activas como ocultar información del servidor, bloquear métodos HTTP innecesarios, proteger archivos críticos y deshabilitar funcionalidades de riesgo como el editor de archivos de WordPress. Cada medida aplicada reduce la superficie de ataque disponible para un adversario.

La implementación de SSL/TLS con OpenSSL demostró el proceso completo de generación de certificados: desde la clave privada RSA hasta el CSR y el certificado autofirmado. Aunque en producción se utilizarían certificados firmados por una CA confiable (como Let's Encrypt), el proceso técnico es idéntico y proporciona comprensión profunda de la infraestructura de clave pública (PKI).

El componente de mayor valor defensivo fue la implementación del WAF ModSecurity con las reglas OWASP CRS. Las pruebas de ataques controlados — XSS y Path Traversal — demostraron que el WAF detecta y bloquea automáticamente patrones maliciosos conocidos, retornando código HTTP 403 y registrando los intentos en el log de auditoría. Esto proporciona tanto protección activa como trazabilidad forense.

En conclusión, la seguridad de aplicaciones web es un proceso continuo que requiere múltiples capas de protección trabajando en conjunto. Ninguna medida aislada es suficiente, pero la combinación de hardening del sistema operativo, configuración segura del servidor web, cifrado de comunicaciones y un WAF con reglas actualizadas establece una postura defensiva robusta que cumple con estándares de la industria como OWASP.

"La seguridad no es un producto, es un proceso."

— Bruce Schneier